

If such a link is posted in the social networking website itself, a user might consider it safe since it begins with the familiar name of the social networking site. The user on clicking on this link is forwarded to a phishing site `totallyevilsite.com` which has a login dialog for the social networking site `youttwitface.com`. The user – thinking that he is simply being asked to confirm his credentials or re-login due to an expired session – enters his login credentials. The rest is history.

Another example of a similar exploit would be if the website has some forwarding mechanism to transfer users from one section of the website to another. For example if a user needs to confirm his age before entering a mature section of the site, the website after checking his age will use some forwarding mechanism to get the user to where he wanted to go. Such a URL might be as follows:

`http://www.youttwitface.com/ageconfirm.php?forward=adult.php`

What if an attacker changes this to:

`http://www.youttwitface.com/ageconfirm.php?forward=admin.php`

If the forwarding mechanism is poor it might redirect the user to sections of the website to which he / she would not otherwise have access.

3.2.12 Conclusion

The web has never been a safe place, but today with the proliferation of new technologies and web development concepts, hackers have an even greater surface to attack. As we wait for the new HTML5-based web standard to emerge, you can be damn sure they will be exploited in ways we cannot imagine right now.

It helps to be prepared, especially when the attack could come from anywhere. You need to think of each user who visits your website as a potential hacker; your site doesn't get 10,000 visits a month, it gets 10,000 potential attackers. A cynical way to look at things surely, but it is also an effort to protect the interests of your other users, err... potential attackers.

No one can ever be fully secure, there are some very smart hackers out there, and many of them are responsible for discovering these exploits in the first place. It is common that a flaw, which would allow an application to be compromised, is only discovered after the fact.

Be prepared for the worst. 